

Firmware 7.15 Stack 09 audit

1. Identity and frozen scope

Owner: Codex agent2, assigned 2026-09-27. Worktree /private/tmp/kk715-stack09-agent2; branch audit/715-stack09-agent2-20260927. The owner directed completion of block09 after block08 on re-entry. Block08 is now integrated and the combined source audit and local gates pass; final hosted evidence is recorded separately in the live PR receipt.

Historical code-bearing [PR #839](#): base dc8c80ec99a84b7f5381759ac03e041b2aadb92f, head d0c1a7c810107b1ce0a2c885a8f8ca875944a882. Initial qualification predecessor 5037e7f24cd68f11a1815be7a77a2aeae06022d7; final block08 predecessor db7c711a6c824c42e7096d4867429bbe94cb6ffb, integrated at b7f25862f92f41a26dae0b56cc3834a66f079753. Qualified runtime source 2c37cce7f777f3282a4f0c8ad9dc7712a734a44c. Python companion [draft #121](#), base d9a02d981ee43fe3e80b28ba02466670e6e8409d, pin 41af909341965c81b8afadd38f299d6f929089af. The containing documentation commit is recorded separately; it cannot identify itself in its contents.

Scope: reconcile every historical path against the predecessor; enforce authenticator identity/secret display bounds, duplicate refusal and legacy duplicate deletion; preserve authorization revocation, storage capacities, decoder bounds and test-helper behavior. No storage format, wire schema, crypto algorithm or trust-policy change. Product branches and release promotion are outside this work. Canonical template/SOP hashes are in the evidence snapshot.

Status	Result
Implementation	Four confirmed block09 findings repaired
Targeted verification	Pass: native, wire, old-code controls and inspected OLED
Integration verification	Local full/BTC pass; final block08 integrated and changes audited; hosted CI outcome belongs in live receipt
Adversarial contract verification	Pass for owned boundaries and combined report gates, including real-Git authority controls
External review delivery	Zero block09 requests; explicitly unauthorized
Finding disposition	B09-001 through B09-004 fixed locally; no confirmed owned finding left open
Release acceptance	Not granted; physical device and assembled-release gates remain separate

2. Git line inventory and plain-language changes

The reconciliation JSON enumerates all 15 historical adjacent paths. Historical range has 194 additions and 97 deletions across 15 paths. The final adjacent inventory below includes this source, PDF, reconciliation and raw evidence. The dedicated PR base release/715-stack-08-base-for-09 is pinned to final block08 db7c711a6c824c42e7096d4867429bbe94cb6ffb, allowing the existing PR workflow to use its platform base as waiver authority.

Surface	Change and evidence
authenticator.h	Minimum new secret length 16 bytes; explicit duplicate error
authenticator.c	Printable exact identity bounds; exact field parsing and lookup; duplicate refusal; two consent screens; all-copy legacy deletion; bounded decimal OTP fields; retains credential/cache wiping
fsm_msg_common.h	Align Ping failure table with inserted duplicate enum
unittests/firmware/authenticator.cpp	Preserve two predecessor tests, adapt only secret fixture and two-screen budget, add seven boundary/cancellation/legacy/vector tests
Python gitlink	Four new wire tests; required AU1–AU4 report evidence on both variants; nine report validation tests. Predecessor authorization-loss test AST unchanged
Audit documents	Current-source reconciliation and reproducible evidence; historical receipt prose is not new validation

The historical top-level Dockerfile change is excluded: actual release builds use the pinned image and do not rebuild that recipe. signing_is_active relocation adds no behavior. kkconfirm_driver.cpp is superseded by the stronger once-only board initializer and rejection sentinel. Existing storage tests use 2600 bytes against a maximum 2525-byte fixture; historical

relocation/increase to 3000 is unnecessary. Source diff inspection preserves the original storage, cipher-cleanup, authorization and decoder tests.

3. Current-source reconciliation and findings

Storage capacity/cipher cleanup, authorization revocation, exact protobuf decoding/terminal abort, token generator byproducts, centered provider icons and Zcash export/account protections are already present in the qualified predecessor. Their code and callers were traced rather than replaying old commits. The JSON gives each historical path its disposition.

Security closure matrix

Every row applies to full and Bitcoin-only products. Runtime source is 2c37cce7f777f3282a4f0c8ad9dc7712a734a44c, host source is 41af909341965c81b8afadd38f299d6f929089af. Public paths are Ping dispatch into addAuthAccount, removeAuthAccount and generateOTP; native tests additionally invoke these production functions directly. The evidence bundle contains the named XML/log artifacts and hashes.

Finding, state/origin and observer	Required boundary and executed positive assertion	Forbidden output and falsification
B09-001: host credential and user refusal; host observes terminal Ping Failure	Duplicate identity cannot replace secret; both enrollment declines return exactly Action cancelled. New table maps every inserted enum correctly. Wire test_block09_duplicate_and_cancellation_have_exact_failures passes	Historical mapping loses the cancel message and aliases duplicate/cancel errors. Old-code wire control fails (block09-negative-wire2.xml)
B09-002: host colon-delimited domain/account; device owner and host observe selected account	Nonempty printable identities at most 11 bytes; exact separators, no skipped empty fields. Boundary tests reject before buttons; valid maximum fields persist only after both screens. All confirmed legacy duplicates delete together; decline preserves storage	Empty components must never alias another identity, persist a credential or yield OTP. Historical parser control fails ExactIdentityAndSecretBoundsRejectBeforeReview in block09-negative-native2.xml
B09-003: host OTP identity and stored secret; device owner reviews exact identity, host receives OTP only after consent	Exact lookup retains independent counter-1 vector 287082; 10-byte legacy secret still works with independent vector 356917. Cancellation clears output/cache; empty slots are excluded	Longer prefix-equivalent identity must never retrieve another account. Historical lookup control fails OtpIdentityCannotAliasStoredPrefixOrEmptyFields in block09-negative-native2.xml
B09-004: host decimal counter/countdown; owner observes bounded review duration	Counter 0 through UINT32_MAX; countdown 0 through 30. Maximum counter reaches consent. Native malformed-input test and wire boundary test pass; elapsed subtraction cannot underflow	Signs, junk suffixes, overflow and countdown 31 must fail before review with empty OTP. Previous production source fc38c54e8 fails the new timing test (block09-negative-time.xml)

Enrollment uses separate complete identity and Base32-secret screens. New secrets decode to 16–20 bytes; legacy short stored secrets remain usable/deletable. Two original native tests retain their assertions; the authorization-loss host test is AST-identical. The final preservation receipt records exact pins and the seven added native tests. Cancellation tests prove both no storage mutation and credential/cache wiping; retry and unrelated-account preservation are exercised.

Actual Vault caller src/bun/index.ts sends exact colon-delimited Ping commands, normalizes unpadding Base32, requires 16–20 decoded bytes and bounds labels to 11 UTF-8 bytes. It sends the time-step counter and remaining seconds within 30. The client permits non-ASCII labels that firmware refuses under the retained printable-ASCII policy; this change does not modify the client. Firmware fails terminally instead of truncating identities. No claim is made that every international label is compatible.

4. Verification and artifact identity

Pinned build image: 7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2. Fresh full/BTC debug builds use cmake -C /src/cmake/caches/emulator.cmake /src, Clang and optional -DKK_BITCOIN_ONLY=ON; ARM uses device.cmake, MinSizeRel and the same variant flag. make -j3 completes. Test commands and complete results are retained as raw logs/XML. Native and wire suites run sequentially because they share UDP ports. No physical device was used.

Check	Result	Evidence and limits
Final native firmware	Full 664 pass; BTC 142 pass; no skips/failures	block09-final-native-{full,btc}.xml

Check	Result	Evidence and limits
Board / crypto	Each variant 19 / 18 pass	block09-{board,crypto}-{full,btc}.xml; unchanged code supporting runs
Zcash crypto	72 pass	block09-zcash-crypto.xml; overlaps full firmware coverage, not 72 extra distinct cases
Final broad host	Full 804 pass / 89 skip; BTC 347 pass / 546 skip; zero failures	block09-final-broad-{full,btc}.xml; all five authenticator cases run and pass on both
Stack06 dedicated contracts	Full 13 pass / 3 skip; BTC 1 pass / 15 skip	block09-stack06-{full,btc}.xml; narrow capability override per dedicated contract
Stack07 dedicated contracts	Full 21 pass / 0 skip; BTC 1 pass / 20 skip	block09-stack07-{full,btc}.xml; expected product exclusions
ARM/SRAM	Both link and budget gates pass	Full reserve 17,800 B; BTC 39,136 B; minimum 16,384 B; largest frame 7,664 B; final ELF/stack archive SHA256 in receipt
Actual JUnit report validation	Both variants return true with no errors	block09-actual-report-validation.json, merged actual XML
Report corruption tests	Python nine pass; combined firmware report/analyzer/preflight 30 pass	block09-combined-gates.log; includes descendant/unrelated-base, complete C/C++ membership and analyzer checks
Old-code controls	Two native identity tests fail, one wire mapping test fails, one native timing test fails as expected	Negative XML is isolated from authoritative passing JUnit
Preflight	All Stage-1 mirrors pass on final runtime source/pin	block09-final-preflight.log; rerun after final integration/document/workflow edits before push
Companion CI	Canonical-smoke passes on Python #121	Firmware hosted exact-head CI identity and outcome recorded in live PR receipt

Broad host uses `KK_FORCE_UDP=1` and the seven inherited staged capability declarations: `evm-max-amount-review`, `evm-unknown-token-review`, `entropy-audit-budget`, `osmosis-wire-guards`, `hive-release-review`, `storage-v19-kdf`, `solana-lut-attestation`. Every skipped name/reason is retained in `block09-skips-{full,btc}.json`. No owned authenticator skip is permitted. Full registry validation requires the production validator and clean registry `9f37816afde954ff6617fb5baa346133e5af26c5`; BTC uses its declared product exclusions. Dedicated predecessor contracts close capabilities hidden by broad-run flags.

OLED enrollment capture has two inspected frames: complete 11-character domain/account and complete 32-character Base32 secret, each legible. Capture predates the timing-only repair; enrollment code/rendering is unchanged. This supports those screens and does not establish physical OLED qualification.

Diagnostics retained: initial unsupported CMake CLI, missing token submodule, exhausted disk/zero-length generated headers and missing host packages were repaired before qualifying runs. Owner approved Docker restart after space recovery. First old-code run was invalidated by an emulator surviving SIGTERM; its bind failure/unexpected pass are not evidence. Corrected controls stop the recorded emulator PID and fail as intended. First preflight caught a const-pointer issue, repaired before final pass. Earlier 663/141 native runs and broad runs predating the timing repair are supporting history only.

5. Report render and local preflight

Block08 final source is integrated without conflicts. Its changes after the initial qualified predecessor are report/preflight/workflow repairs plus comments in Solana options; runtime source, native tests and Python predecessor pin are unchanged. Block09 production/test source hashes equal the qualified runtime snapshot, so local native/ARM/host evidence carries forward with this explicit impact assessment. Final hosted CI must independently qualify the combined workflow and source head.

Combined audit traced event authority, exact skip reasons, empty ledger handling, full analyzer argv/version checks, cache configuration namespace, both Homebrew formatter locations, real C/C++ CMake membership, portable Docker timeout and separate committed/worktree whitespace ranges. Explicit preflight bases now must resolve to ancestors. All 30 gate tests pass. Independent temporary Git reproduction shows the prior push/dispatch bypass; final combined code rejects it for all three supported events. Actual full/BTC dedicated JUnit files pass the combined validator, including exact product skip reasons. Python #121 remains pinned and the report workflow now links #121. No owned skip is introduced.

The owner's new instruction accepts block08 for progression. Its local audit and exact-head CI36354155692 pass. Its records honestly retain ten historical requests and pending fresh external acceptance after the last repairs; block09 does not relabel that review history. No further predecessor review is requested.

Source/PDF inventory is frozen below. Final preflight runs after the last edit and before push; output is retained locally and the live PR receipt binds the containing commit and hosted evidence. All PDF pages must be inspected. This report does not claim an earlier CI run validates later documentation or workflow edits.

6. Copilot checkpoint and completion

Block09 Copilot requests: **zero**. The owner explicitly withholds authorization until agent1 is done, its work is pulled, and the combined candidate is fully audited; this report does not turn that prerequisite into permission. Agent1's separately authorized review budget is not authorization for this branch. Local block09 and combined source/gate audits pass; final hosted qualification and receipt remain required before completion. No release/product merge, publication of firmware binaries or physical-device acceptance is claimed.

CI36356955690 failed its secret scan on two public Git SHA values in the reconciliation dependency map. Both equal actual gitlinks in qualified source2c37cce7f. .gitleaksignore now excludes only the two exact commit/path/rule/line fingerprints; no secret rule or path is broadly excluded. Gitleaks8.30.1 rechecks the introduced history. Firmware/test behavior is unchanged; final preflight and new hosted CI are required.

Complete adjacent inventory

Immutable reproduction range: db7c711a6c824c42e7096d4867429bbe94cb6ffb..88dae2c96b3e2bfd46ebc2c16815537514014ee7. The containing final commit is recorded in the live PR receipt; source/PDF rendering changes after the inventory snapshot retain the same path/count inventory.

Added	Deleted	Path
1	1	.github/workflows/ci.yml
5	0	.gitleaksignore
1	1	deps/python-keepkey
114	0	docs/release/audit-units/715-09-audit-20260927.md
-	-	docs/release/audit-units/715-09-audit-20260927.pdf
-	-	docs/release/audit-units/715-09-local-evidence-20260927.tgz
145	0	docs/release/audit-units/715-09-reconciliation-20260927.json
2	0	include/keepkey/firmware/authenticator.h
111	73	lib/firmware/authenticator.c
1	0	lib/firmware/fsm_msg_common.h
196	4	unittests/firmware/authenticator.cpp